

Der KI-Kompass

für den Industriemittelstand

Vollständiges Schulungskonzept mit Quellenangaben · Version 2.0 · April 2026

Internes Dokument · Prozessia GbR · sebastian.spuhler@prozessia.de

Zeitplan Gesamttag

Zeit / Dauer	Block & Inhalt
09:00-09:20 (20 Min)	Block 0: Ankommen & Kalibrierung
09:20-10:50 (90 Min)	Block 1: Wie KI wirklich funktioniert
10:50-11:05 (15 Min)	Pause
11:05-12:45 (100 Min)	Block 2: Rechtlicher Rahmen I - EU AI Act & DSGVO
12:45-13:30 (45 Min)	Mittagspause
13:30-15:05 (95 Min)	Block 3: Rechtlicher Rahmen II + Lösungen + KI-Compliance
15:05-15:15 (10 Min)	Kaffeepause
15:15-16:30 (75 Min)	Block 4: Chancen & Risiken in der Industrie
16:30-17:00 (30 Min)	Block 5: Quick-Check, 90-Tage-Plan & Abschluss

Bruttodauer 8 Stunden, netto reine Lernzeit 6 h 25 Min. Bewusst Ganzttag statt Halbttag: Halbtage reichen nicht für substanzielle Vermittlung des Rechtsteils und Transfer-Übungen. Fraunhofer IEM, TUV NORD und Bitkom Akademie nutzen alle den Ganzttag als Mindestformat für Entscheider.

Quellen Formatentscheidung: Fraunhofer IEM, KI-Strategie Top-Management (iem.fraunhofer.de); TUV NORD Intensivseminar KI-Management (tuev-nord.de); Bitkom Akademie KI-Kompass (bitkom-akademie.de)

Block 0 – Ankommen und Kalibrierung (20 Min)

Vorstellungsrunde: Jeder Teilnehmer sagt in 60 Sekunden, wo sein Unternehmen bei KI steht (Skala 1-10). Moderatorin notiert Zahlen sichtbar. Typischer Schnitt: 3-4. Entkrampft sofort.

Einstiegsstatistik für die Moderatorin

40 % der deutschen Unternehmen wissen, dass ihre Mitarbeiter heimlich KI nutzen (Bitkom 2025)
Real nutzen 57 % aller Arbeitnehmer KI ohne Wissen der Führung (KPMG/University of Melbourne 2025)

Botschaft: 'Sie haben schon KI im Betrieb. Die Frage ist nicht ob, sondern ob Sie es wissen.'

Bitkom-Unternehmensumfrage 2025 (bitkom.org); KPMG/University of Melbourne Workforce AI Use Survey 2025

Block 1 – Wie KI wirklich funktioniert (90 Min, 09:20-10:50)

Lernziel: Entscheider können drei Sätze eigenständig formulieren: 'Ein LLM ist ein statistischer Wort-Vorhersager.' 'RAG ist nützlicher für mich als Fine-Tuning.' 'Agent ist LLM plus Werkzeuge plus Eigeninitiative.'

1.1 Die KI-Landkarte (20 Min, 09:20-09:40)

Dreistufige Taxonomie als Schaubild: Klassisches Machine Learning (Predictive Maintenance, Anomalieerkennung) → Deep Learning (Computer Vision, Spracherkennung) → Generative KI (LLMs, Bild-/Audio-/Videogeneratoren) → Agenten (LLM + Werkzeuge + Planungsschleife). Historischer Anker: ChatGPT-Launch November 2022 als Wendepunkt.

Quelle Taxonomie: Russell/Norvig, *Artificial Intelligence: A Modern Approach*, 4. Aufl. 2020; Fraunhofer IAIS KI-Kompendium 2024 (iaais.fraunhofer.de)

1.2 So funktioniert ein LLM (30 Min, 09:40-10:10)

Analogie 1 - Der belesene Praktikant:

'Stellen Sie sich ein LLM wie einen Praktikanten vor, der das gesamte Internet gelesen hat - aber in Ihrem Betrieb erst seit heute arbeitet. Hat Allgemeinwissen im Überfluss, null Firmenkontext. Ist eloquent, schnell, und manchmal erfindet er selbstbewusst Unsinn, weil er das Gefühl hat, eine Antwort liefern zu müssen.'

Live-Demo: Halluzination sichtbar machen

Prompt: 'Was besagt DIN EN 16230-7 zur Blechbearbeitung?' - diese Norm existiert nicht, das Modell erfindet plausible Details. Wirkung: Halluzinationseffekt wird live sichtbar. Stärkste Lerneinheit des Tages.

Die sechs Schlüsselkonzepte (je 3 Min):

- Token und Kontextfenster - Schreibtisch-Analogie: Was drauf liegt, sieht das Modell. Was nicht drauf liegt, existiert nicht.
- Halluzination: Die KI weiss nicht, dass sie nichts weiss.
- Training versus Inference: Koch-Analogie. Training kostet Millionen, Inference kostet Cent.
- Prompt Engineering: Briefing-Analogie. Einem Grafiker sagt man auch nicht 'Mach mal was Schönes'.
- Temperature: Der bürokratische Sachbearbeiter versus der kreative Werbetexter.
- Modell-Markt 2026: GPT-5, Claude, Gemini (Closed, US) vs Llama, Mistral, DeepSeek (Open Source) vs Aleph Alpha (DE). Merksatz: Modelle sind Commodity. Kein Vendor Lock-in mehr.

Quellen Block 1.2: Vaswani et al., *Attention Is All You Need*, NeurIPS 2017; OpenAI GPT-4 Technical Report 2023; Anthropic Claude Model Card 2024; Aleph Alpha Produktseite (aleph-alpha.com); Meta Llama 3 Technical Report 2024

1.3 Wie bekomme ich KI auf MEINE Daten? (20 Min, 10:10-10:30)

Entscheidungsbaum: Reicht Allgemeinwissen? → Prompting. Brauche ich Firmendaten? → RAG. Muss das Modell dauerhaft meinen Stil lernen? → Fine-Tuning. In 90 % aller KMU-Fälle reicht RAG.

Merkformel:

'Fine-Tuning ist wie einen Praktikanten in einen Sprachkurs schicken. RAG ist wie ihm Ihre Ordner auf den Tisch legen. Raten Sie, was schneller und günstiger ist.'

Cloud vs On-Premise: EU-Cloud-Pfade (Azure OpenAI EU, Mistral La Plateforme, Claude über AWS Bedrock EU) vs Private Cloud bei deutschem Hosters vs On-Premise mit Llama/Mistral auf eigenem GPU-Server (ab ca. 15.000 EUR Hardware, wirtschaftlich ab 50.000-100.000 Anfragen/Monat).

Quellen RAG/Fine-Tuning: Lewis et al., *Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks*, NeurIPS 2020; Hu et al., *LoRA: Low-Rank Adaptation of Large Language Models*, ICLR 2022; [Cloudmagazin.com](https://cloudmagazin.com) RAG vs. Fine-Tuning vs. Prompt Engineering, April 2026

1.4 Agenten, RPA und Workflow-Automation (15 Min, 10:30-10:45)

Drei-Spalten-Tabelle: RPA (der Fließbandarbeiter - tut exakt das, was man zeigt, bricht bei UI-Änderung) vs Workflow-Automation n8n/Make (vordefinierte Schritte) vs KI-Agent (der Werkstudent - versteht das Ziel, improvisiert). Realitätscheck: Gartner prognostiziert, dass mehr als 40 % der Agentic-AI-Projekte bis Ende 2027 wegen unklarem ROI eingestellt werden. Klein pilotieren, messen, skalieren. MCP (Model Context Protocol) seit Dezember 2025 unter Linux Foundation als neuer Quasi-Standard.

Quellen Block 1.4: Gartner Hype Cycle for Artificial Intelligence 2025; MyBusinessFuture, Prozessautomatisierung 2026 (mybusinessfuture.com); Anthropic MCP-Dokumentation (modelcontextprotocol.io); Wikipedia Model Context Protocol

Block 2 – Rechtlicher Rahmen I: EU AI Act und DSGVO (100 Min, 11:05-12:45)

Lernziel: Jeder Teilnehmer weiss am Ende, ob er Anbieter oder Betreiber ist, welche seiner KI-Anwendungen welcher Risikoklasse zuzuordnen sind, und was bis August 2026 erledigt sein muss.

2.1 Der EU AI Act - Verordnung (EU) 2024/1689 (50 Min, 11:05-11:55)

Inkrafttreten und Zeitplan:

- 01.08.2024: Inkrafttreten
- 02.02.2025: Art. 5 (verbotene Praktiken) und Art. 4 (KI-Kompetenzpflicht) gelten
- 02.08.2025: GPAI-Pflichten, Governance-Stellen
- 02.08.2026: Hochrisiko-Pflichten, Transparenzpflichten Art. 50, CE-Kennzeichnungspflicht Art. 48
- 02.08.2027: Hochrisiko-KI als Sicherheitsbauteil in regulierten Produkten

Quelle: Verordnung (EU) 2024/1689 des Europäischen Parlaments und des Rates vom 13. Juni 2024 (EU AI Act). Amtsblatt der EU L 2024/1689, 12.07.2024. eur-lex.europa.eu/legal-content/DE/TXT/PDF/?uri=OJ:L_202401689

Rollenbestimmung (Art. 3 KI-VO):

Anbieter (Art. 3 Nr. 3): entwickelt oder lässt entwickeln und bringt unter eigener Marke in Verkehr. Betreiber (Art. 3 Nr. 4): verwendet KI-System in eigener Verantwortung, ausser privat. Fast jedes Industrieunternehmen ist Betreiber. Fallstrick Art. 25: Wesentliche Änderung macht aus dem Betreiber einen Anbieter.

Quelle: Art. 3 Nr. 3, 4, Art. 25 Verordnung (EU) 2024/1689. Kommentar: Webersohn & Scholtz, Anbieter oder Betreiber? Die Schlüsselrollen im AI Act (webersohnundscholtz.de, 2025)

Die vier Risikoklassen (Ampel-Darstellung):

- Rot - Verboten (Art. 5): Social Scoring, manipulative Techniken, Emotionserkennung am Arbeitsplatz. Bussgelder bis 35 Mio. EUR oder 7 % Jahresumsatz.
- Orange - Hochrisiko (Art. 6 i.V.m. Anhang I und III): kritische Infrastruktur, HR-Auswahl, Kreditscoring, bestimmte Maschinensicherheitsfunktionen.
- Gelb - Begrenzt (Art. 50): Chatbots müssen sich als KI zu erkennen geben, Deepfakes brauchen Wasserzeichen.
- Grün - Minimal: Spamfilter, Produktempfehlungen. Keine Pflichten.

Quelle: Art. 5, 6, 50, 99 Verordnung (EU) 2024/1689; EU AI Act Explorer: artificialintelligenceact.eu/de/ai-act-explorer/; TUV Risk Navigator: tuev-risk-navigator.ai

Art. 4 KI-Kompetenzpflicht:

Wortlaut: 'Die Anbieter und Betreiber von KI-Systemen ergreifen Massnahmen, um nach besten Kräften sicherzustellen, dass ihr Personal ... über ein ausreichendes Mass an KI-Kompetenz verfügt.' Gilt seit 02.02.2025. Dieser Schulungstag ist dokumentierter Beleg für die Art.-4-Pflicht.

Quelle: Art. 4 Verordnung (EU) 2024/1689; EU AI Act Compliance Checker: artificialintelligenceact.eu/de/bewertung/eu-ai-act-compliance-checker/; IHK Schleswig-Holstein, AI-Act: Was Unternehmen jetzt wissen müssen (ihk.de/schleswig-holstein, 2025)

Interaktionselement: Post-it-Übung

Jeder Teilnehmer listet zwei KI-Anwendungen aus seinem Betrieb auf einem Post-it und klebt sie an die Ampeltafel. Moderatorin kommentiert Ausreisser. Danach live: Compliance Kompass der Bundesnetzagentur (bundesnetzagentur.de/DE/Fachthemen/Digitales/KI/2_Risiko/kompass/start.html).

2.2 DSGVO und KI (50 Min, 11:55-12:45)

Merkformel:

'Jeder Prompt mit einem Namen drin ist personenbezogene Datenverarbeitung.'

Fünf Kernvorschriften:

- Art. 5 Abs. 2 DSGVO (Rechenschaftspflicht): Nicht nur einhalten, sondern nachweisen können. KI-Verzeichnis, DSFA, dokumentierte Prompt-Policy.
- Art. 13/14 DSGVO (Transparenzpflichten): Kunden und Mitarbeiter über KI-Einsatz, Zweck, Empfänger und Drittlandtransfer informieren. Bei automatisierten Entscheidungen zusätzlich die 'involvierte Logik, Tragweite und angestrebten Auswirkungen'.
- Art. 22 DSGVO (Automatisierte Einzelentscheidungen): Grundsätzliches Verbot. EuGH, 07.12.2023, C-634/21 (SCHUFA): Bereits ein KI-Score gilt als automatisierte Entscheidung, wenn Dritte ihm massgebliches Gewicht beimessen. Relevant: HR-Bewerberfilterung, Kreditlimits, Reklamationsbewertung.
- Art. 28 DSGVO (Auftragsverarbeitung): AVV bei Nutzung von ChatGPT Enterprise, Claude Enterprise, Copilot M365, Gemini für Workspace mit EU-Residenz zwingend. Wichtig: Kostenlose Consumer-Versionen (ChatGPT Free, Gemini Privatkonto) bieten KEINEN AVV - ihr Einsatz für personenbezogene Daten ist DSGVO-widrig.
- Drittstaatentransfer: Schrems II (EuGH 16.07.2020, C-311/18): Privacy Shield gekippt. US Cloud Act (2018): US-Behörden können Herausgabe aller US-Anbieter-Daten verlangen. Data Privacy Framework (Adaquanzbeschluss 10.07.2023) gilt, ist aber seit Januar 2025 politisch angeschlagen.

Quellen DSGVO-Block: Verordnung (EU) 2016/679 DSGVO, dsgvo-gesetz.de; EuGH, Urt. v. 16.07.2020, C-311/18 (Schrems II); EuGH, Urt. v. 07.12.2023, C-634/21 (SCHUFA/Datenschutzbehörde Hessen); BfDI, Orientierungshilfe KI und Datenschutz, 2024 (bfdi.bund.de)

Fallbeispiel 1 - Samsung (Marz 2023):

In nur 20 Tagen nach interner ChatGPT-Freigabe drei Leaks: fehlerhafter Source-Code, Produktionsmetriken für Halbleiter-Equipment, kompletter Meeting-Mitschnitt. Reaktion: Prompt-Limit auf 1.024 Byte, dann vollständiges Verbot, eigenes Modell Gauss AI. Botschaft: 'Der Grundungsfall der Shadow-AI-Debatte. 20 Tage gedauert. Die Daten sind unwiederbringlich.'

Quelle: t3n, Samsung-Mitarbeiter leaken Firmengeheimnisse über ChatGPT, Marz 2023 (t3n.de/news/samsung-semiconductor-daten-chatgpt-datenleck-1545913/)

Fallbeispiel 2 - ChatGPT-Datenleck (20. Marz 2023):

Bug in redis-py legte über neun Stunden Chat-Titel, Gesprächsverläufe und Zahlungsdaten von ca. 1,2 % der ChatGPT-Plus-Abonnenten offen. Garante (IT) verhängte am 31.03.2023 temporäres Verarbeitungsverbot. Dezember 2024: 15 Mio. EUR Bussgeld gegen OpenAI. Botschaft: 'Auch die sichersten Anbieter leaken.'

Quelle: Heise.de, ChatGPT-Datenleck ermöglichte Einsicht in Informationen fremder Benutzer, Marz 2023 (heise.de/news/ChatGPT-Datenleck-ermoeglichte-Einsicht-in-Informationen-fremder-Benutzer-8042945.html)

Block 3 – Rechtlicher Rahmen II: GeschGehG, Haftung, Rechtsprechung, Losungen & KI-Compliance (95 Min, 13:30-15:05)

3.1 Geschäftsgeheimnisgesetz (10 Min, 13:30-13:40)

Wortlaut des Schlusselfatbestands (§ 2 Nr. 1 GeschGehG):

Drei Voraussetzungen: (a) Information ist nicht allgemein bekannt und wirtschaftlich wertvoll, (b) angemessene Geheimhaltungsmassnahmen ergriffen, (c) berechtigtes Geheimhaltungsinteresse. Wenn Konstruktionszeichnungen, Kundenlisten oder Source-Code ohne Enterprise-Vertrag in ein öffentliches KI-Tool eingegeben werden, entfällt regelmässigerweise Voraussetzung (b). Der gesetzliche Schutz erlischt.

Quellen: Gesetz zum Schutz von Geschäftsgeheimnissen (GeschGehG), [gesetzte-im-internet.de/geschgehg/](https://www.gesetze-im-internet.de/geschgehg/); insbesondere § 2 Nr. 1 GeschGehG ([gesetzte-im-internet.de/geschgehg/___2.html](https://www.gesetze-im-internet.de/geschgehg/___2.html)); § 23 GeschGehG (Strafbarkeit)

3.2 Haftung (15 Min, 13:40-13:55)

§ 823 BGB: Haftung bei fahrlässiger oder vorsätzlicher Pflichtverletzung (z.B. unzureichende Wartung eines KI-Systems). Neue EU-Produkthaftungsrichtlinie (RL 2024/2853) vom 18.11.2024, Umsetzungsfrist 09.12.2026: Software und KI gelten ausdrücklich als Produkt. Haftung verschuldensunabhängig, erfasst fehlende Sicherheitsupdates. Die ursprünglich geplante EU-KI-Haftungsrichtlinie (AI Liability Directive) wurde am 16.07.2025 von der EU-Kommission zurückgezogen.

Quellen: § 823 BGB ([gesetzte-im-internet.de/bgb/___823.html](https://www.gesetze-im-internet.de/bgb/___823.html)); Produkthaftungsgesetz ProdHaftG ([gesetzte-im-internet.de/prodhaftg/](https://www.gesetze-im-internet.de/prodhaftg/)); EU-Richtlinie 2024/2853 über die Haftung für fehlerhafte Produkte, Amtsblatt EU vom 18.11.2024 (eur-lex.europa.eu/legal-content/DE/TXT/?uri=celex%3A32024L2853); EU-Kommission, Rücknahme AI Liability Directive, ABl. EU 06.10.2025

3.3 Aktuelle Rechtsprechung - fünf Landmark-Fälle (15 Min, 13:55-14:10)

- KG Berlin, 2020: Kein Urheberrechtsschutz für rein KI-generierte Werke (§ 2 Abs. 2 UrhG erfordert menschliche Schöpfung). Bestätigt durch LG Köln, 30.09.2024, 14 O 150/23.
- LG Kiel, 29.02.2024, 6 O 151/23: Unternehmen haftet als Storer für falsche KI-generierte Wirtschaftsauskünfte. Kernsatz: 'Ein Unternehmen kann sich nicht darauf zurückziehen, dass es am automatisierten Vorgang nicht weiter beteiligt sei.'
- LG Hamburg, 27.09.2024, 310 O 227/23 (LAION-Fall): TDM nach § 44b, § 60d UrhG bei Forschungszwecken grundsätzlich zulässig. OLG Hamburg, 10.12.2025: Berufung zurückgewiesen.
- LG München I, 11.11.2025, 42 O 14139/24 (GEMA ./ OpenAI): LLM, das Songtexte reproduzierbar memorisiert, begeht urheberrechtsrelevante Vervielfältigung. TDM-Schranke bei kommerzieller Output-Nutzung verneint.
- Mata v. Avianca, S.D.N.Y., 22.06.2023: Anwalt zitiert sechs von ChatGPT erfundene Präzedenzfälle. Sanktionen: 5.000 USD gegen Schwartz, 5.000 USD gegen LoDuca, 5.000 USD gegen Kanzlei.

Quellen: KG Berlin, 2 U 12/16 Kart (openjur.de/u/2252960.html); LG Kiel, 6 O 151/23 (openjur.de/u/2497511.html); LG Hamburg, 310 O 227/23 (openjur.de/u/2495651.html); Spiegel.de, New Yorker Anwalt blamiert sich mit Fake-Urteilen aus ChatGPT (spiegel.de/netzwelt/apps/new-york-anwalt-blamiert-sich-mit-fake-urteilen-aus-chatgpt-a-8935d1c8); EuGH C-634/21 SCHUFA; LG Köln 14 O 150/23

3.4 Schatten-KI und drei Warngeschichten (10 Min, 14:10-14:20)

Zahlen Schatten-KI:

- 57 % der Arbeitnehmer nutzen KI heimlich (KPMG/University of Melbourne 2025)
- 54 % der Wissensarbeiter in Deutschland nutzen KI ohne Unternehmensfreigabe (Software AG 2025)
- Shadow-AI-Breaches kosten im Schnitt 4,63 Mio. USD - 670.000 USD mehr als herkömmliche Breaches (IBM Cost of a Data Breach 2025)

Quellen: KPMG/University of Melbourne, Workforce AI Survey 2025; IBM Security, Cost of a Data Breach Report 2025 (ibm.com/security/data-breach); Software AG, Digital Transformation Report 2025; edv-trend.de, Shadow-AI im Unternehmen, Dezember 2025

Warngeschichte 1 - CEO Fraud mit KI-Stimme (2019/2024):

Marz 2019: UK-CEO einer deutschen Energiekonzern-Tochter überweist 220.000 EUR nach Anruf mit KI-geklonter Stimme des deutschen Mutter-CEO. Erster dokumentierter Fall von KI-Voice-Fraud. Dann Hongkong Februar 2024: Arup verliert 25 Mio. USD durch Deepfake-Videocall mit gefälschtem CFO.

Quellen: Sueddeutsche Zeitung, KI-Deepfake-Versicherung-Betrug, 2019 ([sueddeutsche.de/wirtschaft/ki-deepfake-versicherung-betrug-1.4493902](https://www.sueddeutsche.de/wirtschaft/ki-deepfake-versicherung-betrug-1.4493902)); WSJ, Fraudsters Use AI to Mimic CEOs Voice, August 2019; Bloomberg, Arup Deepfake Fraud \$25 Million, Februar 2024

Warngeschichte 2 - Franziska Giffey und der falsche Klitschko (24.06.2022):

Damalige Regierende Bürgermeisterin Berlins telefonierte 30 Min via Webex mit gefälschter Klitschko-Stimme/Deepfake-Video. Auch Wien, Madrid, Budapest, Barcelona betroffen. Mit 2022-Technologie, die heute frei verfügbar ist.

Quelle: Spiegel.de, Franziska Giffey telefoniert mit falschem Vitali Klitschko ([spiegel.de/politik/deutschland/vermeintlicher-buergermeister-talk-franziska-giffey-telefoniert-mit-falschem-vitali-klitschko-a-cfb365ad](https://www.spiegel.de/politik/deutschland/vermeintlicher-buergermeister-talk-franziska-giffey-telefoniert-mit-falschem-vitali-klitschko-a-cfb365ad))

Warngeschichte 3 - Googles Bard und der Aktiensturz (Februar 2023):

In einem Werbe-Demo beantwortete Bard die Frage, welches Teleskop die ersten Exoplaneten fotografiert habe, falsch (behauptete das James-Webb-Teleskop, korrekt war Hubble). Alphabet-Aktie fiel innerhalb eines Tages um 8 % - Marktwertverlust von ca. 100 Mrd. USD.

Quelle: Spiegel.de, Google Bard Falschinformation lässt Aktienkurs fallen ([spiegel.de/netzwelt/apps/google-bard-falschinformation-des-chatbots-sorgt-fuer-fallenden-aktienkurs-a-4cbf7461](https://www.spiegel.de/netzwelt/apps/google-bard-falschinformation-des-chatbots-sorgt-fuer-fallenden-aktienkurs-a-4cbf7461))

3.5 Compliance-Tools (5 Min, 14:20-14:25)

- TUV AI Act Risk Navigator: tuev-risk-navigator.ai - kostenloses Multiple-Choice-Tool zur Risikoklassifizierung
- EU AI Act Compliance Checker (Future of Life Institute): artificialintelligenceact.eu/de/bewertung/eu-ai-act-compliance-checker/
- Compliance Kompass der Bundesnetzagentur: bundesnetzagentur.de/DE/Fachthemen/Digitales/KI/2_Risiko/kompass/start.html
- EU AI Act Explorer (Gesetzestext navigierbar): artificialintelligenceact.eu/de
- EU AI Act Chatbot (Österreich RTR): chat.ki.rtr.at

Quellen: TUV Sud AG (tuvsud.com); Future of Life Institute (futureoflife.org); Bundesnetzagentur (bundesnetzagentur.de); RTR Österreich (rtr.at)

3.6 DSGVO-konforme Infrastruktur - es gibt Antworten (15 Min, 14:25-14:40)

Moderationshinweis: Der Tag endet NICHT mit Angst. Jetzt kommt die Antwort auf alles Bisherige.

Botschaft in einem Satz: 'Sie müssen nicht zwischen KI und Datenschutz wählen. Sie müssen nur die richtige Infrastruktur wählen.'

Weg 1 - EU-Cloud-Server am Beispiel Hetzner:

Für Unternehmen die KI selbst hosten wollen. Hetzner: seit 1997 in Gunzenhausen, Rechenzentren ausschliesslich in Deutschland und Finnland, deutsches und europäisches Recht, kein Cloud Act, kein US-Jurisdiction-Risiko. AVV nach Art. 28 DSGVO standardmassig verfügbar.

- Skalierbarkeit: Einstieg ab ca. 38 EUR/Monat (4 vCPU, 16 GB RAM, CCX23), Upgrade in Minuten ohne Replatforming
- Flexibilität: Kein Vendor Lock-in. Modell, Anwendung und alle Daten verbleiben auf eigenem Eisen. Bei Kündigung nimmt man alles mit.
- DSGVO-Compliance: Kein Drittstaatentransfer, kein Cloud Act, kein Privacy-Shield-Risiko. Rechenschaftspflicht nach Art. 5 Abs. 2 vollständig erfüllt.
- Geeignet für: Unternehmen mit sensiblen Konstruktionsdaten, M&A-Unterlagen, oder Kundendaten die ein eigenes RAG-System oder KI-Agenten-System betreiben.

Quelle: Hetzner Online GmbH, Produktseite Cloud Compute & Dedicated Root Server (hetzner.com); Hetzner Datenschutzinformationen und AVV (hetzner.com/legal/privacy-policy/)

Weg 2 - Azure OpenAI Service (Microsoft, EU-Region):

Für Unternehmen die Frontier-Modelle ohne eigene GPU-Infrastruktur nutzen wollen. Microsoft schliesst standardmassig einen DPA/AVV nach Art. 28 DSGVO. EU-Region (West Europe: Amsterdam, North Europe: Dublin): Daten verlassen europäisches Territorium nicht. Keine Nutzung von Eingabedaten für

Modell-Training. EU Data Boundary-Programm seit Januar 2023 bestätigt. Zertifizierungen: SOC 2, ISO 27001, ISO 27701.

- Geeignet für: Unternehmen in Office-365-Umgebungen (nahtlose Integration) oder als Sprachmodell-Backend für KI-Agenten

Quellen: Microsoft Azure OpenAI Service - Datenschutz und Compliance (azure.microsoft.com/de-de/products/ai-services/openai-service/); Microsoft EU Data Boundary (microsoft.com/en-us/trust-center/privacy/european-data-boundary); Microsoft GDPR Compliance (microsoft.com/de-de/trust-center/privacy/gdpr-overview)

Die Prozessia-Architektur: Optimale Kombination

EU-Server (z.B. Hetzner) für die Applikationsschicht, Agenten-Logik und Vektordatenbank
Azure OpenAI EU als datenschutzkonformes Sprachmodell-Backend
Kein Datum verlässt die EU, keine Firmendaten gehen ins Training
Volle Skalierbarkeit, echter Vendor-Exit möglich
Kurz motto: EU-Server für die Applikation. EU-Cloud für das Modell. DSGVO-Problem gelöst.

Abschlussbotschaft des Rechtsteils:

'Recht und Technik sprechen nicht gegen KI. Sie definieren den Rahmen, innerhalb dessen KI wirklich Wert schafft. Wer diesen Rahmen kennt, ist nicht im Nachteil - er ist im Vorteil gegenüber den 79 %, die noch kein Governance-Framework haben.'

Quelle Statistik: Maximal Digital, KI-Studie 2025 (maximal.digital/studie-ki-im-mittelstand-und-kmu-2025)

3.7 KI-Compliance als dauerhaftes System (20 Min, 14:40-15:05) - Basierend auf Modul 6

KI-Compliance ist kein Projekt mit Enddatum, sondern eine Betriebsfunktion - wie Qualitätsmanagement. Analogie: 'Compliance ist wie Leitplanken auf der Autobahn. Sie bremsen nicht. Sie verhindern Unfälle. Wer Leitplanken als Einschränkung erlebt, fährt falsch.'

Was KI-Compliance konkret bedeutet: Verantwortung verstehen - Risiken minimieren - Regeln definieren. Ziele: Rechtssicherheit erhöhen, Haftung vermeiden, Vertrauen schaffen intern wie extern.

Nicht nur Hochrisiko-KI braucht Compliance - jeder, der KI einsetzt, braucht sie, auch bei inoffizieller Nutzung durch Mitarbeitende. Chatbots fallen unter begrenztes Risiko (Transparenzpflicht, Kennzeichnung), Spamfilter unter minimales Risiko (Risikobewertung durch Anbieter empfohlen).

Der Kreislauf der KI-Compliance (5 Stationen):

1. KI-Einsatz erkennen - Vollständige Inventarisierung aller KI-Systeme inkl. Schatten-KI. Mitarbeiterbefragung, IT-Audit, Netzwerkmonitoring.
2. Risiken bewerten - Systematische Risikoanalyse je Anwendung: Risikoklasse nach KI-VO, DSGVO-Prüfung, Geheimschutz-Check, Haftungsbewertung. Die Post-it-Übung aus Block 2 war der erste Schritt.
3. Massnahmen ergreifen und dokumentieren - Technisch (EU-Cloud, AVV, Zugriffsrechte, Logging, TOMs) und organisatorisch (Richtlinie, Positivliste, Verantwortliche), Kennzeichnung von KI-Outputs nach aussen.
4. Schulen und kommunizieren - Regelmässige Mitarbeiterunterweisungen nach Art. 4 KI-VO, dokumentiert mit Datum und Inhalt. Dieser Tag heute ist Schulungsbeleg Nr. 1 - die Teilnahmebestätigung ist Beweismittel.
5. Auditieren und verbessern - Interne Audits, Hinweisgebersystem (ab 50 MA ohnehin Pflicht nach HinSchG), regelmässiger Review ob neue Tools hinzugekommen sind.

Zwei Schlüsselpositionen:

- KI-Beauftragter: analog zum Datenschutzbeauftragten, koordiniert den Kreislauf, übernimmt Dokumentationspflicht
- Tone from the top: GF-Aussage in der nächsten Besprechung - 'Wir nutzen KI. Hier sind die Regeln.' - hat mehr Wirkung als zehn IT-Mails

Dokumentation als Schutzschild:

- KI-Register: welche Systeme, welche Zwecke, welche Risikoklasse, welche Schutzmassnahmen
- Schulungsnachweis-Ordner: wer wurde wann in was unterwiesen (Art. 4 KI-VO-Nachweis)

- Incident-Log: was ist passiert, wie wurde reagiert

Merksatz: 'Wer dokumentiert, der bleibt. Das ist exakt das, was die Bundesnetzagentur ab August 2026 als erstes anfordern wird.'

Quellen KI-Compliance: Modul 6 Schulungsunterlagen Prozessia (eigene Inhalte); Bundesnetzagentur, Compliance Kompass; BfDI, Orientierungshilfe zu Beschädigten-KI 2024; Hinweisgeberschutzgesetz HinSchG, BGBl. I 2023 Nr. 140; EU AI Act Art. 4, 48, 50, 70, 99

Block 4 – Chancen und Risiken in der Industrie (75 Min, 15:15-16:30)

4.1 Fünf kritische Risiken in der Praxis (15 Min)

- Schatten-KI: Gegenmasnahme: Nutzungsrichtlinie mit Positivliste, Enterprise-Verträge für 2-3 freigegebene Tools, DNS-Filter, CASB
- Fehlerhafte Outputs: RAG auf eigenen Daten, Quellenzwang im Prompt, menschliche Endprüfung bei jeder Aussenwirkung
- Datenverlust: Kein Consumer-Account für Firmendaten, EU-Residenz in Verträgen, regelmäßiges TIA
- Deepfakes und CEO Fraud: Vier-Augen-Prinzip bei Zahlungen, Rückruf-Verifikation auf bekannten Nummern, Codewort-Verfahren
- KI-generiertes Phishing: MFA überall, keine Transaktion aufgrund E-Mail allein, kontinuierliches Phishing-Training

Quellen: IBM Security, *Cost of a Data Breach 2025*; KPMG *AI Risk Survey 2025*; BSI, *Lagebericht zur IT-Sicherheit 2024* ([bsi.bund.de](https://www.bsi.bund.de)); Gartner, *Top Security and Risk Trends 2025*

4.2 Zehn Industrie-Use-Cases als Nutzen-Aufwand-Matrix (25 Min)

Quick Wins (niedriger Aufwand, hoher Nutzen):

- Transkription und Protokollierung (Meetings, Service-Einsätze): Standard-Tools, 1-2 Wochen, sofort 30-60 Min/Protokoll gespart
- Interner Wissens-Chatbot (RAG auf eigenen Dokumenten): 4-12 Wochen, 20.000-80.000 EUR. 80 % der Standardanfragen automatisiert. Use Case Nr. 1 für jeden Maschinenbauer > 30 MA.

Strategische Projekte:

- Angebotserstellung und -kalkulation: KI zieht Daten aus CRM/ERP, schlägt Preis und Text vor. 40-70 % Zeitersparnis.
- Stucklistenenerstellung und -validierung (BOM): KI prüft Konsistenz, Doppelungen, Fehler. Hoch-Nutzen in variantenreicher Einzelfertigung.
- Beschaffungsagent: Bedarfsprognose, Bestellmengenoptimierung, automatischer Angebotsvergleich aus PDF. Typisch 5-15 % Bestandssenkung.
- Technische Dokumentation: mehrsprachige Anleitungen aus CAD und BOM, semantische Suche.

Hoherwertige Projekte:

- Predictive Maintenance: Sensor-ML sagt Ausfälle 48h-4 Wochen voraus. 40.000-100.000 EUR Pilotprojekt. Fraunhofer-Referenz: 168.000 EUR/Jahr Einsparpotenzial bei 280-MA-Betrieb.
- Qualitätskontrolle mit Computer Vision: Kamera + CV erkennt Fehler in Echtzeit. Ausschussquote - 40-90 %. 40.000-120.000 EUR/Linie.
- Anomalieerkennung in Prozess- und Energiedaten.
- Kundensupport-Chatbots: 30-60 % der Standardfälle automatisierbar.

Quellen Use Cases: Fraunhofer IAIS, *KI-Innovation-Workshops Industrie* (iais.fraunhofer.de); VDMA, *Maschinenbau in Zahl und Bild 2025*; McKinsey Global Institute, *The Economic Potential of Generative AI 2023*; Bitkom, *KI-Monitor 2025*

4.3 Drei Praxisbeispiele aus der Industrie (15 Min)

Praxisbeispiel A - Stucklistenagent bei Sondermaschinenbauer:

Ausgangslage: manuelle BOM-Prüfung pro Anlage ca. 12 Stunden. Lösung: Agent mit Function Calling auf PLM-System, prüft Konsistenz, fehlende Normteile, Dubletten, plausibilisiert Stückzahlen gegen Zeichnungsstand. Ergebnis: Prüfaufwand auf ca. 3 Stunden reduziert, Fehlerquote in Fertigungsanmeldung deutlich gesunken. Keine Cloud-Ausleitung, DSGVO-konform.

Praxisbeispiel B - Beschaffungsagent bei Serienfertiger:

Ausgangslage: 15-40 Lieferantenangebote pro Ausschreibung in PDF, manuelle Vergleichstabelle war Flaschenhals. Lösung: Agent extrahiert Preise, Lieferzeiten, Zahlungsbedingungen, Qualitätsnachweise aus PDFs, gleicht mit ERP ab, schlägt Preisanker für Verhandlungen vor. Ergebnis: Vergleichserstellung von 4 Stunden auf 20 Minuten, bessere Preiskonditionen durch systematische Datenbasis.

Praxisbeispiel C - Interner Chatbot bei 120-MA-Maschinenbauer:

Ausgangslage: Service, Vertrieb, Fertigung riefen ständig den gleichen Senior-Konstrukteur an. Lösung: RAG-Chatbot auf EU-gehostetem LLM, indexiert ca. 8.000 PDF-Dokumente. Ergebnis: 80 % der Standardanfragen ohne Senior-Kontakt geklärt, Servicetechniker auf Baustelle erhalten in Sekunden Antworten mit Quellenangabe. Wissen der ausscheidenden Konstrukteure konserviert.

Moderationshinweis: Alle drei Beispiele werden ohne Nennung von Prozessia als Lieferant präsentiert. Die Moderatorin sagt: 'Drei Beispiele aus meiner Projektpraxis mit Industriekunden.'

4.4 Quick-Check: Welche Prozesse sind KI-ready? (20 Min)

Jeder Teilnehmer erhält ein zweiseitiges Arbeitsblatt mit Bewertung nach fünf Dimensionen: Datenreife, Prozessfrequenz, Entscheidungslogik, Risiko/Haftung, Veränderungsbereitschaft (je 0-2 Punkte).

Anwendung auf 3-5 eigene Prozesse. Dann Peer-Austausch in Dreiergruppen: 'Was mich überzeugt / Was ich hinterfragen wurde / Was ich auch mal ausprobieren wurde.' Wirksamstes Transfer-Element des Tages.

Methode: angelehnt an Bitkom Akademie AI-Potenzialanalyse-Methodik 2024 und Fraunhofer IEM Management-Workshop-Format

Block 5 – 90-Tage-Plan und Abschluss (30 Min, 16:30-17:00)

5.1 Der persönliche 90-Tage-Plan (15 Min)

Tag 1-30:

- Rollenbestimmung nach KI-VO durchführen (mit Compliance Kompass BNetzA)
- KI-Nutzungsrichtlinie in Auftrag geben oder selbst aufsetzen
- Bestandsaufnahme aller genutzten KI-Tools (inkl. Schatten-KI)
- Einen Enterprise-Account für ein freigegebenes Tool einrichten

Tag 31-60:

- Ersten Use Case pilotieren (Empfehlung: Transkription oder Wissens-Chatbot)
- Datenschutzfolgenabschätzung für den Pilot anstossen
- Dokumentierte Mitarbeiter-Unterweisung nach Art. 4 KI-VO durchführen

Tag 61-90:

- Pilot-Ergebnisse auswerten, Business Case für ersten Skalierungs-Use-Case erstellen
- Datenstrategie-Workshop ansetzen
- KI-Beauftragten oder externen Partner auswählen

5.2 Peer-Commitment-Runde und Abschluss (15 Min)

Jeder Teilnehmer stellt in 90 Sekunden seinen ersten 30-Tage-Schritt vor. Die Gruppe stellt genau eine konkrete Rückfrage. Sozialer Druck zur Umsetzung, wirksamste Transfer-Sicherung des Tages.

Mitnahme-Zusammenfassung als Laminat: 'Ein LLM ist ein statistischer Wort-Vorhersager - gut, aber halluzinationsfähig. Für Firmendaten brauche ich meistens RAG.' / 'Ich bin Betreiber nach KI-VO, seit Februar 2025 verpflichtet zur KI-Kompetenz, ab August 2026 kommen weitere Pflichten. Ich dokumentiere alles.' / 'DSGVO und Datenschutz sind lösbar: EU-Server für die Applikation, EU-Cloud für das Modell. Kein Grund, nicht anzufangen.'

Teilnahmebestätigung wird persönlich übergeben: wichtig als Nachweis für Art. 4 KI-VO. Offene Gespräche bei Getränken. Visitenkarte Prozessia.

Die Handout-Mappe - Inhalt (10 Dokumente)

6. KI-Landkarte (Laminat A4): dreistufige Taxonomie ML/DL/Generative KI/Agenten mit typischen Use Cases und Abgrenzung zu RPA
7. Glossar der 10 Schluselbegriffe: LLM, Token, Halluzination, Prompt, RAG, Fine-Tuning, Agent, MCP, On-Premise vs Cloud, Multimodalität
8. Entscheidungsbaum 'Prompting - RAG - Fine-Tuning' (Laminat)
9. EU-AI-Act-Fahrplan (A3-Poster): alle Fristen 2025-2027 mit Pflichten und Bussgeldhöhe
10. Rollenbestimmungs-Checkliste: Fünf-Schritte-Baum Anbieter/Betreiber/Hochrisiko/Transparenz
11. Rechts-Merkblatt Industrie-KI (4 Seiten): Kernartikel im Wortlaut mit Praxiskommentar
12. Fallsammlung '5 Warngeschichten': Samsung, ChatGPT-Leak, CEO-Fraud 220k EUR, Giffey/Klitschko, Mata v. Avianca
13. Tool-Liste Compliance (1 Seite): TUV Risk Navigator, EU AI Act Compliance Checker, Compliance Kompass BNetzA, Quick-Start
14. Quick-Check-Arbeitsblatt 'KI-Readiness' (2 Seiten, wiederverwendbar im Führungskreis)
15. 90-Tage-Plan (1 Seite, bereits in der Schulung ausgefüllt)

Hinweis: Alle Handouts enthalten QR-Codes auf die jeweiligen Gesetzestexte und Quellen. Quellenverzeichnis Gesamtdokument siehe folgende Seite.

Vollständiges Quellenverzeichnis

Gesetze und Verordnungen

- Verordnung (EU) 2024/1689 (EU AI Act): eur-lex.europa.eu/legal-content/DE/TXT/PDF/?uri=OJ:L_202401689
- Verordnung (EU) 2016/679 (DSGVO): dsgvo-gesetz.de
- Gesetz zum Schutz von Geschäftsgeheimnissen (GeschGehG): gesetze-im-internet.de/geschgehg/
- § 823 BGB: gesetze-im-internet.de/bgb/_823.html
- Produkthaftungsgesetz (ProdHaftG): gesetze-im-internet.de/prodhaftg/
- EU-Produkthaftungsrichtlinie 2024/2853: eur-lex.europa.eu/legal-content/DE/TXT/?uri=celex%3A32024L2853
- Hinweisgeberschutzgesetz (HinSchG), BGBl. I 2023 Nr. 140

Rechtsprechung

- EuGH, 16.07.2020, C-311/18 (Schrems II)
- EuGH, 07.12.2023, C-634/21 (SCHUFA)
- KG Berlin, 16.01.2020, 2 U 12/16 Kart: openjur.de/u/2252960.html
- LG Kiel, 29.02.2024, 6 O 151/23: openjur.de/u/2497511.html
- LG Hamburg, 27.09.2024, 310 O 227/23: openjur.de/u/2495651.html
- LG Köln, 30.09.2024, 14 O 150/23 (KI-Urheberrecht)
- LG München I, 11.11.2025, 42 O 14139/24 (GEMA ./ OpenAI)
- OLG Hamburg, 10.12.2025, 5 U 104/24 (LAION Berufung)
- U.S. District Court S.D.N.Y., Sanctions Opinion Mata v. Avianca, 22.06.2023

Behördenquellen

- Bundesnetzagentur, Compliance Kompass KI: bundesnetzagentur.de/DE/Fachthemen/Digitales/KI/2_Risiko/kompass/start.html
- BfDI, Orientierungshilfe KI 2024: bfdi.bund.de
- BSI, Lagebericht IT-Sicherheit 2024: bsi.bund.de
- EU AI Act Explorer: artificialintelligenceact.eu/de/ai-act-explorer/
- EU AI Act Compliance Checker: artificialintelligenceact.eu/de/bewertung/eu-ai-act-compliance-checker/
- TÜV Risk Navigator: tuev-risk-navigator.ai
- EU AI Act Chatbot RTR Österreich: chat.ki.rtr.at
- OECD, Hiroshima AI Process Reporting Framework 2025: oecd.org/en/about/news/press-releases/2025/02/oecd-launches-global-framework

Wissenschaft und Forschung

- Vaswani et al., Attention Is All You Need, NeurIPS 2017
- Lewis et al., RAG for Knowledge-Intensive NLP Tasks, NeurIPS 2020
- Hu et al., LoRA, ICLR 2022
- McKinsey Global Institute, The Economic Potential of Generative AI, Juni 2023
- Fraunhofer IAIS, KI-Innovation-Workshops Industrie: iais.fraunhofer.de
- Fraunhofer IEM, KI-Strategie Top-Management: iem.fraunhofer.de

Branchenberichte und Medien

- IBM Security, Cost of a Data Breach Report 2025: ibm.com/security/data-breach
- Bitkom, KI-Monitor 2025: bitkom.org
- KPMG/University of Melbourne, Workforce AI Survey 2025
- Gartner, Hype Cycle for Artificial Intelligence 2025
- t3n, Samsung Datenleck ChatGPT 2023: t3n.de/news/samsung-semiconductor-daten-chatgpt-datenleck-1545913/

- Heise.de, ChatGPT Datenleck 2023: heise.de/news/ChatGPT-Datenleck-ermoeglichte-Einsicht-in-Informationen-fremder-Benutzer-8042945.html
- Spiegel.de, CEO Fraud Deepfake: spiegel.de/wirtschaft/ki-deepfake-versicherung-betrug-1.4493902
- Spiegel.de, Giffey Klitschko: spiegel.de/politik/deutschland/vermeintlicher-buergermeister-talk-franziska-giffey-telefoniert-mit-falschem-vitali-klitschko-a-cfb365ad
- Spiegel.de, Bard Aktiensturz: spiegel.de/netzwelt/apps/google-bard-falschinformation-des-chatbots-sorgt-fuer-fallenden-aktienkurs-a-4cbf7461
- Spiegel.de, Anwalt Fake-Urteile: spiegel.de/netzwelt/apps/new-york-anwalt-blamiert-sich-mit-fake-urteilen-aus-chatgpt-a-8935d1c8
- Maximal Digital, KI-Studie 2025: maximal.digital/studie-ki-im-mittelstand-und-kmu-2025
- TUV NORD, Intensivseminar KI-Management: tuev-nord.de
- Bitkom Akademie, Advanced GenAI: bitkom-akademie.de/workshop/advanced_GenAI

Infrastruktur und Anbieter

- Hetzner Online GmbH: hetzner.com, hetzner.com/legal/privacy-policy/
- Microsoft Azure OpenAI: azure.microsoft.com/de-de/products/ai-services/openai-service
- Microsoft EU Data Boundary: microsoft.com/en-us/trust-center/privacy/european-data-boundary
- Aleph Alpha: aleph-alpha.com
- Mistral AI: mistral.ai
- Meta Llama: ai.meta.com/llama/
- Model Context Protocol: modelcontextprotocol.io